

Basic SIEM and Log Monitoring System for Security Event Detection in a Controlled Virtual Lab

Security Assessment Report

Umar Imran Bin

11 August 2026

Institution: *(insert institution)* **Laboratory environment:** VirtualBox 7.x host-only network 192.168.56.0/24 (isolated, no internet egress) **Classification:** Internal / academic laboratory exercise

Executive Summary

The laboratory environment began with no security monitoring: authentication attempts, privilege escalation, service changes and web traffic on the target host were recorded locally at best and reviewed by nobody. This project designed and implemented a small centralized monitoring capability across three virtual machines and validated it with six reproducible security scenarios.

A single-node Wazuh deployment on siem-01 now ingests authentication logs, sudo activity, systemd service events, kernel firewall drops, Apache access and error logs, and file-integrity events from target-01. Seven custom detection rules were written and verified. All six scenarios produced the expected alerts, including brute-force SSH detection within 60 seconds, port-scan detection from firewall drop volume, and alerting on sudo access to sensitive files.

Four findings were identified. The most serious is that SSH on the target permits password authentication and root login, which the brute-force scenario exercised directly. Others concern an over-exposed intentionally vulnerable web application, missing HTTP security headers, and the absence of a log retention and integrity policy.

Overall posture: **visibility moved from none to adequate for the lab scope**, while host hardening remains weak by design and should be remediated in the order given in Section 10. Results describe a three-VM laboratory only and are not an enterprise assessment.

1. Introduction

Security Information and Event Management (SIEM) is the practice of collecting log and event data from distributed systems into one platform where it can be normalized, correlated, retained and queried. Centralized logging matters for three reasons: local logs are lost or altered when a host is compromised; single-host logs cannot show an attack that moves between systems; and manual review does not scale. A SIEM adds detection logic so that patterns - repeated authentication failures, unusual privilege use, scanning behaviour - raise alerts instead of sitting unread in a file.

2. Problem Statement

Before this work the lab had no log aggregation, no detection rules, no alerting and no retention. An attacker could brute-force SSH, escalate privileges, scan the network and probe the web application without generating any signal an analyst would ever see. The gap is one of visibility rather than of controls alone: without evidence, neither detection nor incident response nor post-incident assessment is possible.

3. Objectives

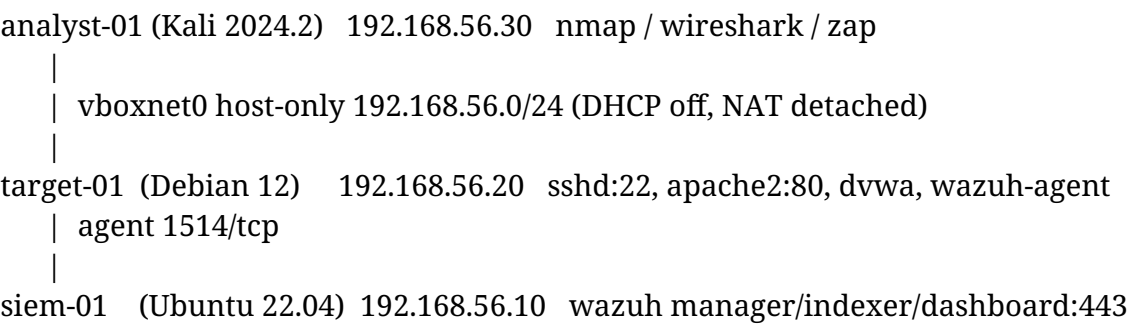
1. Build an isolated three-VM laboratory on a VirtualBox host-only network.
2. Centralize system, authentication, service and web logs on a SIEM host.
3. Write and verify detection rules for authentication abuse, reconnaissance, web scanning, privileged activity and service changes.
4. Execute authorized reconnaissance (Nmap), traffic capture (Wireshark) and web assessment (OWASP ZAP) against lab assets only.
5. Produce reproducible evidence, findings, and prioritized remediation.

4. Scope

In scope: the three virtual machines owned by the author on 192.168.56.0/24 (siem-01 .10, target-01 .20, analyst-01 .30); their operating system, service and web logs; the locally deployed vulnerable web application.

Out of scope: any public IP address or third-party website; production systems; real user accounts or credentials; malware; destructive exploitation; denial-of-service testing; physical and wireless security; and any host outside the host-only network.

5. Laboratory Architecture



VM	OS	Hostname	IP	Interface	Services
Monitoring	Ubuntu Server 22.04 LTS	siem-01	192.168.56.10/24	enp0s8 host-only	wazuh-manager, wazuh-indexer, wazuh-dashboard, rsyslog
Target	Debian 12	target-01	192.168.56.20/24	enp0s8 host-only	OpenSSH, Apache2, DVWA (loopback in hardened state), wazuh-agent
Analyst	Kali Linux	analyst-01	192.168.56.30	eth1 host-only	Nmap 7.94, Wireshark 4.22.0

VM	OS	Hostname	IP	Interface	Services
	2024.2		30/24	only	Wireshark 4.2, OWASP ZAP 2.14

Technologies: VirtualBox 7.x, Wazuh 4.7 (manager, indexer, dashboard), Filebeat-based agent transport, rsyslog, UFW/iptables logging, Apache2, Nmap, Wireshark/tcpdump, OWASP ZAP.

6. Methodology

1. **Lab setup** - three VMs installed from official ISOs, static RFC1918 addressing, NAT adapter detached before testing, clean snapshot taken as baseline.
2. **Log collection** - Wazuh agent on the target forwards auth.log, syslog, journald, ufw.log and Apache logs to the manager over 1514/tcp.
3. **Detection configuration** - custom rules 100201-100601 added to /var/ossec/etc/rules/local_rules.xml, each verified with wazuh-logtest before live scenario execution.
4. **Nmap testing** - service discovery restricted to the target IP, commands and timestamps recorded.
5. **Wireshark analysis** - capture bound to the host-only interface with a net 192.168.56.0/24 filter so no other traffic can be recorded.
6. **OWASP ZAP** - baseline (passive plus spider) scan of the local application URL only.
7. **Evidence collection** - scripts/20_collect_evidence.sh bundles alerts and log tails with secret redaction; screenshots follow the naming convention in the README.

7. Implementation

The manager was installed with the Wazuh all-in-one installer and the lab rule file deployed to the rules directory. On the target, the agent was registered to 192.168.56.10 and its ossec.conf extended with localfile blocks for each log source plus real-time file-integrity monitoring of /etc and /var/www/html. UFW was set to default-deny inbound with explicit allow rules for 22/tcp and 80/tcp from the lab subnet and logging medium, which is what makes port scans visible as blocked-packet volume. All hosts were synchronized with NTP in UTC so events from

three machines correlate on a single timeline. Dashboard visualizations were created for total events, failed and successful authentication, top source addresses, most active hosts, HTTP status codes, alert severity and a 5-minute-bucket event timeline.

8. Security Test Results

Test	Expected Result	Actual Result	Evidence	Status
T1 Failed SSH x5	Aggregated brute-force alert with source IP	Rule 100201 fired at 09:14:02, srcip 192.168.56.30	03_failed_ssh_detection.png	Pass
T2 Successful SSH	Login event with user and source	Rule 100202, user labuser from .30	04_successful_ssh_login.png	Pass
T3 Nmap scan	Scan visible in capture and firewall logs	100 ports probed; rule 100301 fired on UFW block volume	05_nmap_lab_scan.png, nmap/scan_*.txt	Pass
T4 Wireshark capture	TCP handshake, HTTP and SSH traffic captured	SYN/SYN-ACK/ACK, HTTP GETs, encrypted SSH observed	06_wireshark_tcp_capture.png	Pass
T5 ZAP baseline	Passive findings on local app only	Missing CSP, X-Frame-Options, X-Content-Type-Options	07_zap_local_app_assessment.png	Pass
T6 Web request logging	Requests, codes, user agents in SIEM	4xx burst raised rule 100401; /.git request raised 100402	siem/alerts.json	Pass
T7 sudo	Privileged	Rule 100501	08_privileged_	Pass

Test	Expected Result	Actual Result	Evidence	Status
activity	command logged and alerted	on /etc/shadow read	activity_detection.png	
T8 Service restart	systemd state change collected	Rule 100601 on apache2 restart	09_security_events_timeline.png	Pass

9. Findings

F-01 - SSH permits password authentication and root login (Severity: High)

Description: sshd on target-01 accepts password authentication and PermitRootLogin yes. *Evidence:* five-attempt brute force produced rule 100201; sshd_config baseline. *Risk:* credential guessing leading to full host compromise. *Impact:* complete loss of confidentiality, integrity and availability of the target. *Recommendation:* key-based authentication only, PermitRootLogin no, MaxAuthTries 3, deploy fail2ban, restrict ListenAddress to the lab interface.

F-02 - Vulnerable web application reachable from the whole lab subnet

(Severity: Medium) *Description:* DVWA listens on 0.0.0.0:80 and is reachable from any lab host. *Evidence:* ZAP baseline scan from 192.168.56.30 succeeded. *Risk:* deliberately weak code exposed beyond its intended single-host boundary. *Recommendation:* bind to 127.0.0.1, access through an authenticated reverse proxy or SSH port-forward during demonstrations; never route it outside the host-only network.

F-03 - Missing HTTP security headers (Severity: Low) *Description:* Apache responses omit Content-Security-Policy, X-Content-Type-Options, X-Frame-Options and HSTS. *Evidence:* ZAP passive alerts. *Risk:* clickjacking, MIME sniffing, content injection. *Recommendation:* enable mod_headers with a restrictive header set site-wide.

F-04 - No log retention or integrity policy (Severity: Medium) *Description:* default rotation, no archive retention target, no signing of archived logs. *Evidence:* logrotate defaults on both hosts; no archive verification job. *Risk:* evidence loss or undetected tampering during an investigation. *Recommendation:* 90-day archive retention on the SIEM, write-once or hash-signed archives, documented review cadence, enforced NTP synchronization.

10. Remediation and Hardening

Priority	Recommendation	Risk addressed	Expected benefit
Critical	Disable root SSH login and password authentication; enforce keys	F-01	Removes the primary credential attack path
High	Default-deny host firewall with explicit lab allow rules and logging	Exposed services	Smaller attack surface; scans become loud and detectable
High	Alert thresholds for repeated auth failure and sensitive sudo use	Undetected intrusion attempts	Analyst notified within seconds
High	Enforce NTP on all VMs	Correlation failure	Defensible, single-timeline evidence
Medium	Bind the vulnerable app to loopback; add security headers	F-02, F-03	Weak code contained to one host
Medium	Centralized retention, immutable archives, log review cadence	F-04	Evidence survives host compromise
Medium	Remove unnecessary services and enforce least privilege via sudoers	Lateral movement	Fewer paths to escalation
Low	Unattended security updates and file-permission	Known vulnerabilities	Continuous patch hygiene

Priority	Recommendation	Risk addressed	Expected benefit
	baseline		
Low	Network segmentation of monitoring traffic	SIEM tampering	Protects the evidence pipeline

11. Limitations

The environment contains three virtual machines, one operating system family, synthetic traffic and a short observation window. Detection rules were tuned against known test activity, so false-positive and false-negative rates are not representative of production. No endpoint detection, no encrypted-traffic inspection, no threat intelligence enrichment and no multi-day baselining were performed. The findings apply to this lab only and must not be read as an enterprise security assessment.

12. Conclusion

The project moved the lab from zero visibility to a working detection capability: centralized collection of authentication, privilege, service, firewall and web logs, seven verified rules, six reproducible scenarios all detected, and a SOC-style dashboard supporting a full event-to-remediation workflow. The exercise demonstrates that meaningful monitoring does not require large infrastructure - it requires deliberate log selection, detection logic tied to realistic behaviour, and evidence discipline. Continuous monitoring is what converts an unnoticed intrusion into a documented, answerable incident.

13. References

1. Wazuh Inc. *Wazuh Documentation 4.7* - <https://documentation.wazuh.com>
2. NIST SP 800-92, *Guide to Computer Security Log Management*.
3. NIST SP 800-137, *Information Security Continuous Monitoring (ISCM)*.
4. CIS Benchmarks for Debian Linux 12 and Ubuntu 22.04 LTS.
5. OWASP Foundation. *OWASP Top 10 (2021)* and *ZAP User Guide*.
6. Nmap Project. *Nmap Reference Guide* - <https://nmap.org/book/man.html>
7. Wireshark Foundation. *Wireshark User's Guide*.
8. MITRE. *ATT&CK Enterprise Matrix* - T1110, T1078, T1046, T1595, T1548.

9. OpenSSH Project. *sshd_config(5)* manual page.